Phoenix-Threat Model

Service	Provider	Purpose	Data Classification	SLA Required

Ask to AI ChatGPT Assistant Show less

Phoenix Application

Security Threat Model & Risk Assessment Report

Version:1.0**Date:**23 January 2026**Classification:**Internal / Confidential**Status:**Draft

Table of Contents

1. Executive Summary
2. Document Information
3. Objective
4. Application Description
5. Methodology (STRIDE)
6. Data Flow Diagram
7. Entry & Exit Points
8. Critical Security Findings
9. Risk Register
10. STRIDE Analysis by Component
11. Attack Surface Summary
12. Recommended Security Controls
13. Component & Service Inventory
14. Document Approval

Executive Summary

This threat model assessment identifies security risks within the Phoenix AI Platform using the STRIDE methodology. The assessment revealed **15 security risks** requiring attention, with **5 critical findings** related to hardcoded credentials that require immediate remediation.

5Critical

4High

4Medium

2Low

1. Document Information

Field	Value
Application Name	Phoenix AI Platform

Application Version	January 2026 Release
Document Version	1.0
Next Review Date	23 April 2026

Service	Provider	Purpose	Data Classification	SLA Required

Document Authorization

Version	Date	Author	Reviewed By	Remarks
1.0	23 Jan 2026	Security Team	CISO	Initial Release

2. Objective

The objective of this threat model for Phoenix AI Platform is to comprehensively identify, assess, and prioritize potential security threats and vulnerabilities within the platform's architecture and ecosystem.

Goal	Description
Identify Threats	Identify potential threats, attack vectors, and weaknesses in the platform's design, components, and interactions
Assess Risks	Evaluate the potential impact and likelihood of each identified threat to prioritize remediation efforts
Prioritize Mitigations	Develop risk-based prioritization of security mitigations based on severity and business impact
Enhance Controls	Recommend and implement security best practices and technical controls
Enable Improvement	Establish a framework for ongoing security monitoring and continuous improvement

3. Application Description

Phoenix AI Platform is an intelligent enterprise application that leverages artificial intelligence and machine learning capabilities to automate business processes and enhance decision-making. The platform is built on a microservices architecture hosted on AWS.

Key Capabilities

Capability	Description	Technology
AI-Powered Agent Services	Langflow-based agent	OpenAI, Anthropic Claude,
Document Processing	AI-powered document classification, extraction, and analysis	OpenAI Vision, FastAPI
Workflow Orchestration	Distributed workflow execution and state management	Temporal Cloud, Spring Boot
Data Management	Multi-database support for transactional and analytical workloads	PostgreSQL, MongoDB, Redis, Snowflake
External Integrations	Web search, voice processing, and third-party AI services	Tavily, Whisper, Multiple LLM Providers

Service	Provider	Purpose	Data Classification	SLA Required

4. Methodology: STRIDE Threat Model

This assessment uses the STRIDE threat modeling framework developed by Microsoft to systematically identify and categorize security threats.

Code	Category	Description
S	Spoofing	Threats related to unauthorized identity or entity impersonation, including authentication bypass
T	Tampering	Concerns regarding unauthorized modification of data or code, including injection attacks
R	Repudiation	Risks associated with denial of actions or events, insufficient audit trails
I	Information Disclosure	Unauthorized exposure of sensitive information, data leakage, credential exposure
D	Denial of Service	Attacks aimed at making a system or service unavailable to legitimate users

E	Elevation of Privilege	Unauthorized escalation of user privileges or permissions

Service	Provider	Purpose	Data Classification	SLA Required

5. Data Flow Diagram

DFD Diagram File

5.1 DFD Overview

Element Type	Symbol	Description
External Entity	Rectangle	Users, administrators, and external systems that interact with the platform
Process	Circle/Oval	Application components that process, transform, or route data
Data Store	Cylinder	Databases and storage systems where data is persisted
Data Flow	Arrow	Movement of data between components with labeled protocols
Trust Boundary	Dashed Line	Separation between zones with different trust levels

5.2 Trust Boundaries

Zone	Trust Level	Components	Security Controls
Internet Zone	**Untrusted**	End Users, Admin Users	WAF, DDoS Protection, TLS 1.3
DMZ	**Semi-Trusted**	CloudFront, ALB	Edge Security, Request Filtering
Application Zone	**Trusted**	All Microservices (P3.0 - P11.0)	JWT Auth, mTLS, Security Groups
Data Zone	**Highly Trusted**	PostgreSQL, MongoDB, Redis, Snowflake	Encryption, RBAC, Audit Logging

External Services	**Third-Party**	OpenAI, Anthropic, Google, Tavily, Temporal	API Keys, TLS, Data Minimization

Service	Provider	Purpose	Data Classification	SLA Required

ID	Process Name	Technology	Function
1.0	CloudFront + WAF	AWS	Edge caching, DDoS protection, request filtering
2.0	Application Load Balancer	AWS ALB	Traffic distribution, health checks, TLS termination
3.0	UI Platform	React/TypeScript	User interface, client-side rendering
4.0	Agent Service	Python/Langflow	AI agent orchestration, flow execution
5.0	LLM Services	Python/FastAPI	LLM integration, prompt processing
6.0	App Manager	Go/Chi	Business logic, API gateway
7.0	Data Manager	Go/Gin/gRPC	Data access layer, entity management
8.0	Workflow Service	Java/Spring Boot	Workflow orchestration, state management
9.0	Document Service	Python/FastAPI	Document processing, AI classification
10.0	AWS Cognito	AWS	Authentication, user management, JWT issuance
11.0	S3 Storage	AWS S3	Document storage, file management

5.4 Data Store Inventory

ID	Data Store	Type	Data Classification	Encryption

D1	PostgreSQL (RDS)	Relational	High - PII, Business Data	AES-256 at rest, TLS in transit
D2	MongoDB Atlas	Document	High - Agent	AES-256 at rest,

Service	Provider	Purpose	Data Classification	SLA Required
D3	Redis	Cache	Medium - Session Data	TLS in transit
D4	Snowflake	Data Warehouse	High - Analytics Data	AES-256 at rest, TLS in transit
D5	S3 Bucket	Object Storage	High - Documents	AES-256 (SSE-S3)

5.5 Data Flow Reference

Flow ID	Source	Destination	Data Description	Protocol	Auth Method
DF1	End Users	CloudFront	Web Requests	HTTPS/TLS 1.3	None (Public)
DF2	CloudFront	ALB	Filtered Traffic	HTTPS	Origin Access
DF3-4	ALB	Services	API Requests	HTTP/2	Security Groups
DF5-9	Services	Services	Internal API Calls	gRPC/REST	JWT Tokens
DF10	App Manager	Cognito	Auth Tokens	HTTPS	AWS IAM
DF12	Data Manager	PostgreSQL	SQL Queries	TLS	Username/Password
DF13	Agent Service	MongoDB	Document Operations	TLS	Username/Password
DF14	App Manager	Redis	Cache Operations	TLS	AUTH Token
DF15	Data Manager	Snowflake	Analytics Queries	TLS	Username/Password
DF16-19	LLM Services	AI Providers	Prompts/Responses	HTTPS	API Keys
DF20	Workflow Service	Temporal Cloud	Workflow State	mTLS	JWT Token
DF21	S3 Process	S3 Bucket	Documents	HTTPS	IAM Role

5.6 Threat Hotspots on DFD

Critical Data Flow Threats

Service	Provider	Purpose	Data Classification	SLA Required
Data Flow	Threat	Risk Level	Issue	
DF16-19 (LLM to AI Providers)	Information Disclosure	**Critical**	Hardcoded API keys in source code	
DF12 (Data Manager to PostgreSQL)	Information Disclosure	**Critical**	Hardcoded database credentials	
DF13 (Agent to MongoDB)	Information Disclosure	**Critical**	Hardcoded MongoDB credentials	
DF5-6 (Agent/LLM Services)	Tampering	**High**	Prompt injection vulnerability	
DF20 (Workflow to Temporal)	Spoofing	**High**	JWT token exposure	
DF15 (Data Manager to Snowflake)	Information Disclosure	**High**	Hardcoded Snowflake credentials	

6. Entry & Exit Points

Entry Points

#	Name	Description	Security Controls	Trust Level
1	**Login Page**	Primary user authentication via AWS Cognito	Brute-force protection, MFA, secure session management, TLS 1.3	Low
2	**CloudFront Distribution**	CDN entry point with WAF protection	AWS Shield DDoS protection, TLS 1.2/1.3, WAF rules, geo-blocking	High
3	**Application Load Balancer**	Traffic distribution to ECS services	WAF integration, HTTPS enforcement, path-based routing	Low

4	**File Upload Endpoint**	Document uploads via Document Service to S3	File type validation, AV scanning, S3 encryption, pre-	Low

Service	Provider	Purpose	Data Classification	SLA Required
5	**API Endpoints**	REST/gRPC API for service communication	JWT authentication, rate limiting, input	Medium

Exit Points

#	Name	Description	Security Controls	Data Sensitivity
1	**API Response**	Data returned to authenticated users	Data sanitization, response filtering, HTTPS	Variable
2	**S3 Storage**	Document and file storage	AES-256 encryption, IAM policies, bucket versioning, access logging	High
3	**Database Connections**	PostgreSQL, MongoDB, Redis, Snowflake	Encryption at rest/transit, RBAC, audit logging, connection pooling	High
4	**External AI Services**	OpenAI, Anthropic, Google, Tavily	API key rotation, TLS, data minimization, request logging	High
5	**Temporal Cloud**	Workflow execution state and data	mTLS, namespace isolation, JWT validation, encrypted payloads	High

7. Critical Security Findings

Immediate Action Required

The following hardcoded credentials were discovered during the security assessment and require immediate remediation. These findings represent the highest priority security risks.

Finding	Location	Risk	Required Action
Anthropic API Key	LLM Services	**Critical**	Rotate immediately,

Service	Provider	Purpose	Data Classification	SLA Required

Tavily API Key `tvly-dev-*`	LLM Services codebase	**High**	Rotate and migrate to Secrets Manager
AWS Access Key `AKIASV5IB2PQ5UXIJXNW`	Infrastructure code	**Critical**	Deactivate immediately, use IAM roles instead
MongoDB Credentials `mongo-admin:oVN0...`	Application configuration	**Critical**	Rotate credentials, use Secrets Manager
PostgreSQL Credentials `neo_db_user:5w72...`	Application configuration	**Critical**	Rotate credentials, implement IAM DB authentication
Temporal Cloud JWT Token	Workflow Service	**High**	Rotate token, implement secure token storage
Snowflake Credentials	Data Manager	**High**	Migrate to Secrets Manager with rotation

8. Risk Register

Risk ID	Threat Description	Affected Component	Likelihood	Impact	Risk Level	Status
PHX-001	Hardcoded Anthropic API Key exposure	LLM Services	High	Critical	**Critical**	Open
PHX-002	Hardcoded Tavily API Key exposure	LLM Services	High	High	**High**	Open
PHX-003	Hardcoded AWS Access Key in code	Infrastructure	High	Critical	**Critical**	Open

PHX-004	MongoDB credentials in source code	Data Layer	High	Critical	**Critical**	Open

Service	Provider	Purpose	Data Classification	SLA Required

	credentials in source code					
PHX-006	Temporal Cloud JWT Token exposure	Workflow Service	Medium	High	**High**	Open
PHX-007	Snowflake credentials in codebase	Data Manager	Medium	High	**High**	Open
PHX-008	OAuth client secrets hardcoded	Authentication	Medium	High	**High**	Open
PHX-009	Potential prompt injection attacks on LLM	LLM Services	Medium	Medium	**Medium**	Open
PHX-010	Insufficient API rate limiting	All Services	Medium	Medium	**Medium**	Open
PHX-011	Potential cross-tenant data access	Data Manager	Low	High	**Medium**	Open
PHX-012	Insufficient AI interaction audit logging	LLM Services	Medium	Low	**Low**	Open
PHX-013	S3 bucket misconfiguration risk	Document Service	Low	High	**Medium**	Open
PHX-014	JWT token expiration	Authentication	Low	Medium	**Low**	Open

	configuration					
PHY-015	MFA not	AWS	Medium	High	**Medium**	Open

Service	Provider	Purpose	Data Classification	SLA Required

9. STRIDE Analysis by Component

9.1 UI Platform (React/TypeScript)

Category	Threat	Mitigation
Spoofing	Session hijacking, authentication token theft	Secure JWT handling, HttpOnly cookies, Cognito MFA enforcement
Tampering	Client-side data manipulation, XSS attacks	Server-side validation, Content Security Policy headers
Repudiation	Denial of user actions	Comprehensive audit logging, CloudWatch integration
Information Disclosure	Token/data exposure in browser storage	Avoid localStorage for secrets, use secure cookies
Denial of Service	Request flooding attacks	Rate limiting at ALB/CloudFront level
Elevation of Privilege	Unauthorized admin access	Role-based UI rendering, server-side authorization checks

9.2 Agent Service (Python/Langflow)

Category	Threat	Mitigation
Spoofing	Service impersonation attacks	JWT authentication, mutual TLS for service communication
Tampering	Workflow manipulation, prompt injection	Workflow integrity verification, input sanitization
Repudiation	Denial of agent-initiated actions	LangSmith tracing, MongoDB audit logs
Information Disclosure	API key exposure in code/logs	**Critical** Remove hardcoded keys, use Secrets Manager
Denial of Service	External API quota exhaustion	Rate limiting, circuit breakers, request queuing

Elevation of Privilege	Unauthorized data access via agents	Least privilege principle, sandboxed execution

Service	Provider	Purpose	Data Classification	SLA Required

Category	Threat	Mitigation
Spoofing	Unauthorized service access	JWT authentication, service mesh identity
Tampering	Prompt injection, response manipulation	Prompt validation, output filtering, guardrails
Repudiation	LLM interaction denial	LangSmith logging, request/response storage
Information Disclosure	API keys, PII in prompts	**Critical** Secrets Manager, PII detection/masking
Denial of Service	Service overwhelm, API limits	Request queuing, response caching, provider fallbacks
Elevation of Privilege	Jailbreak attacks on LLM	Prompt security patterns, output validation

9.4 Data Manager (Go/Gin/gRPC)

Category	Threat	Mitigation
Spoofing	Service impersonation	gRPC authentication with JWT, mutual TLS
Tampering	SQL/NoSQL injection attacks	**Critical** Remove hardcoded creds, parameterized queries
Repudiation	Data modification denial	Complete audit trail, soft deletes with history
Information Disclosure	Database credentials, Snowflake access	**Critical** Secure credential management, field encryption
Denial of Service	Connection pool exhaustion	Connection pooling, query timeouts, Redis caching
Elevation of Privilege	Cross-tenant data access	Tenant ID validation, row-level security policies

9.5 Workflow Service (Java/Spring Boot/Temporal)

Category	Threat	Mitigation
Spoofing	Unauthorized workflow triggers	**High** Secure Temporal JWT, workflow authentication

Service	Provider	Purpose	Data Classification	SLA Required

		history
Repudiation	Workflow execution denial	Temporal built-in history, comprehensive audit logging
Information Disclosure	Workflow payload exposure	Encrypt workflow data, custom data converter
Denial of Service	Workflow queue flooding	Rate limiting, activity timeouts, namespace quotas
Elevation of Privilege	Cross-namespace access	Temporal RBAC, JWT scope validation

9.6 Document Service (Python/FastAPI)

Category	Threat	Mitigation
Spoofing	Unauthorized document access	JWT authentication, pre-signed URL validation
Tampering	Document content modification	S3 versioning, integrity checksums
Repudiation	Document operation denial	S3 access logging, CloudTrail integration
Information Disclosure	Sensitive document exposure	S3 encryption, bucket policies, access controls
Denial of Service	Storage exhaustion	Upload size limits, S3 lifecycle policies
Elevation of Privilege	Cross-user document access	Document ownership validation, IAM policies

10. Attack Surface Summary

Attack Surface	Attack Vectors	Risk Level	Priority
API Layer	Injection attacks, broken authentication,	**High**	P1

	rate limit bypass, BOLA vulnerabilities		
AI/LLM Integration	Prompt injection, API jailbreak attacks	**Critical**	P0
Database Services	SQL/NoSQL injection, credential exposure, unencrypted connections	**Critical**	P0
External Integrations	Man-in-the-middle attacks, credential theft, insecure API communication	**Critical**	P0
AWS Infrastructure	IAM misconfiguration, secret exposure, S3 bucket misconfiguration	**Critical**	P0
Authentication	Session hijacking, token theft, weak password policies	**High**	P1
File Upload	Malicious file upload, path traversal, file type bypass	**Medium**	P2

Service	Provider	Purpose	Data Classification	SLA Required

11. Recommended Security Controls

Immediate Actions (P0 - Critical Priority)

1. **Rotate ALL exposed API keys** immediately (Anthropic, OpenAI, Tavily, AWS)
2. **Rotate ALL database credentials** (PostgreSQL, MongoDB, Snowflake)
3. **Migrate all secrets to AWS Secrets Manager** with automatic rotation enabled
4. **Implement secrets scanning** in CI/CD pipeline (git-secrets, truffleHog, Gitleaks)
5. **Deactivate exposed AWS access key** (AKIASV5IB2PQ5UXIJXNW) and transition to IAM roles

Short-Term Actions (P1 - High Priority)

1. Implement comprehensive rate limiting across all API endpoints
2. Enable AWS WAF with OWASP Top 10 ruleset
3. Enforce MFA for all AWS Cognito users
4. Implement prompt injection detection and prevention controls
5. Add PII detection for data sent to external LLM providers

6. Configure S3 bucket policies to block public access

Medium-Term Actions (P2)

1. Enable PostgreSQL audit logging using pgaudit extension

Service	Provider	Purpose	Data Classification	SLA Required

3. Review and tighten all security group rules (least privilege)
4. Enable AWS GuardDuty for threat detection
5. Centralize application logs in CloudWatch Logs Insights
6. Implement automated security scanning in deployment pipeline

Long-Term Actions (P3)

1. Implement Zero Trust architecture principles
2. Deploy AWS Security Hub for centralized security findings
3. Establish regular penetration testing schedule
4. Develop incident response playbooks for credential exposure
5. Implement data loss prevention (DLP) controls

12. Component & Service Inventory

Internal Components

Component	Technology Stack	Port	Data Store	External Dependencies
UI Platform	React / TypeScript	3000	-	CloudFront, Cognito
Agent Service	Python / Langflow	7860	MongoDB Atlas	OpenAI, Anthropic, Google Gemini
LLM Services	Python / FastAPI	8000	-	OpenAI, Anthropic, Gemini, Tavily
App Manager	Go / Chi	8080	PostgreSQL, MongoDB, Redis	Cognito
Data Manager	Go / Gin / gRPC	8082	PostgreSQL, Redis, Snowflake	-
Workflow Service	Java / Spring Boot	8081	PostgreSQL	Temporal Cloud, Cognito
Document Service	Python / FastAPI	8083	PostgreSQL	S3, OpenAI

External Service Dependencies

Service	Provider	Purpose	Data Classification	SLA Required
		inference		
OpenAI Whisper	OpenAI	Voice transcription	Medium Sensitivity	Yes
Anthropic Claude	Anthropic	Alternative LLM inference	High Sensitivity	Yes
Google Gemini	Google Cloud	Alternative LLM inference	High Sensitivity	Yes
Tavily	Tavily	Web search API	Medium Sensitivity	No
Temporal Cloud	Temporal	Workflow orchestration	High Sensitivity	Yes
MongoDB Atlas	MongoDB Inc.	Document database	High Sensitivity	Yes
Snowflake	Snowflake Inc.	Data warehouse	High Sensitivity	Yes

13. Document Approval

Role	Name	Signature	Date
Chief Information Security Officer			
VP of Engineering			
Chief Architect			
Security Team Lead			

Document Classification: Internal / Confidential

This document should be reviewed and updated quarterly or when significant architectural changes occur.

Next scheduled review: April 2026